

IntelliAudit: Using Large Language Models to Evaluate Audit Controls

Anonymous submission

Abstract

IT audits require auditors to judge whether heterogeneous organizational evidence satisfies security and compliance controls. This evidence-evaluation step is difficult to automate: controls are written at a semantic level, evidence is scattered across documents, spreadsheets, screenshots, and operational records, and the final judgment depends on sufficiency, missing evidence, and professional context rather than keyword matching alone. We present INTELLIAUDIT, a retrieval-grounded multi-agent system for assisting IT audit control assessment. INTELLIAUDIT decomposes each assessment into evidence retrieval, primary audit reasoning, adversarial review of adverse findings, and independent adjudication. The system produces an auditor-facing recommendation with cited evidence, a rationale, missing-evidence analysis, and remediation guidance, while preserving the human auditor as the final decision maker. We instantiate INTELLIAUDIT for ISO/IEC 27001:2022 and construct a benchmark of 15 representative controls spanning textual, tabular, visual, and multimedia evidence. We evaluate INTELLIAUDIT with a single-agent ablation and a human study involving audit experts and audit-preparation users. Insert final headline result: e.g., expert preference for multi-agent output, average Likert scores, and key modality result.

Introduction

IT audit engagements are evidence-heavy processes in which auditors assess whether an organization has implemented controls required by a standard such as ISO/IEC 27001:2022. In practice, this requires more than reading the control text. Auditors must interpret the control objective, identify admissible evidence, inspect artifacts across multiple formats, determine whether the evidence is sufficient, and explain gaps in a way that the audited organization can remediate. These tasks remain labor-intensive because evidence is distributed across policy documents, spreadsheets, screenshots, incident records, and other operational artifacts.

Large language models (LLMs) appear well suited to this setting because they can interpret natural language requirements and synthesize explanations. However, audit evidence evaluation is a high-accountability task: unsupported claims,

hallucinated evidence, or premature compliance judgments can mislead both auditors and organizations. A useful system must therefore ground its reasoning in retrieved artifacts, expose the evidence behind each conclusion, handle partial and missing evidence, and allow human auditors to challenge the output.

To address this gap, we develop INTELLIAUDIT as an audit-assistance system rather than an automated auditor. Given a control and an evidence corpus, INTELLIAUDIT searches for relevant artifacts, evaluates whether the retrieved evidence supports the control, challenges adverse findings through a second review stage, and adjudicates disagreements into an auditor-facing recommendation. The output includes a compliance status, cited evidence, a rationale, missing-evidence analysis, and remediation guidance. This design reflects how audit work is performed in practice: conclusions must be grounded in inspectable evidence, but the final judgment remains with the human auditor.

We study the following question: *Can retrieval-grounded LLM agents assist the evidence-evaluation phase of IT auditing in a way that is explainable, robust to heterogeneous artifacts, and useful to auditors?* We operationalize this question through four research questions: (RQ1) whether LLMs can reason about audit controls beyond surface text; (RQ2) whether they can evaluate the factual sufficiency of supporting evidence; (RQ3) whether this reasoning extends across document, spreadsheet and image artifacts; and (RQ4) whether the resulting explanations help non-auditors prepare for an audit.

This paper makes three contributions. First, we formulate IT audit evidence evaluation as an explainable, evidence-grounded recommendation task rather than an autonomous certification task. Second, we introduce INTELLIAUDIT, a multi-agent workflow that combines retrieval, primary assessment, adversarial review, adjudication, and human feedback. Third, we construct an ISO 27001 benchmark with simulated but audit-realistic organizational evidence and evaluate the method through expert review feedback.

Related Work

LLMs for compliance and audit. Recent work has explored the use of LLMs for compliance question answering, audit planning, and audit support. RAGulating Compliance uses multi-agent retrieval and structured regulatory knowl-

This is an anonymized submission for review purposes only. Distribution, citation, or public sharing of this manuscript is strictly prohibited. Copyright and publication details will appear in the final version if accepted.

edge to answer compliance questions (Agarwal et al. 2025). Smart Audit explores LLM-assisted supply-chain audit workflows and reports operational efficiency gains in an industrial setting (Yao et al. 2024). Brachten and Riasat study the feasibility of automating ISO 27001 consultancy and auditing through expert interviews, highlighting both the demand for automation and practitioner concerns about accuracy and sensitive information (Brachten and Riasat 2024). Other work evaluates the readiness of cybersecurity governance frameworks for LLM integration and emphasizes the need for expert-in-the-loop validation (McIntosh et al. 2024). INTELLIAUDIT differs from these efforts by focusing specifically on the evidence-evaluation phase of IT auditing and by structuring the task around evidence bundles, adversarial review, and auditor-facing explanations.

Human-in-the-loop LLM auditing. Human-AI collaboration has been shown to improve auditing and failure discovery in LLM systems. AdaTest++ demonstrates that collaborative human-AI auditing can expose failure modes that neither humans nor automated methods find alone (Rastogi et al. 2023). This motivates the design of INTELLIAUDIT as an assistant whose output can be inspected, challenged, and revised by a human auditor rather than accepted as an autonomous decision.

Multi-agent reasoning and document understanding. Multi-agent debate and adjudication can improve factuality and reasoning by forcing models to compare competing interpretations (Du et al. 2023). Audit assessment naturally contains such conflicts: an initial finding may appear adverse, but compensating or overlooked evidence may change the conclusion. INTELLIAUDIT adapts this idea to audit evidence by using a Defender agent to challenge adverse findings and a Judge agent to adjudicate disagreements. The benchmark also requires reasoning over enterprise documents and visual artifacts, connecting to work on layout-aware and multimodal document understanding such as DocLLM (Wang et al. 2024).

Human-in-the-loop LLM auditing. Human-AI collaboration has been shown to improve auditing and failure discovery in LLM systems. AdaTest++ demonstrates that collaborative human-AI auditing can expose failure modes that neither humans nor automated methods find alone (Rastogi et al. 2023). This motivates the design of INTELLIAUDIT as an assistant whose output can be inspected, challenged, and revised by a human auditor rather than accepted as an autonomous decision.

Multi-agent reasoning and document understanding. Multi-agent debate and adjudication can improve factuality and reasoning by forcing models to compare competing interpretations (Du et al. 2023). Audit assessment naturally contains such conflicts: an initial finding may appear adverse, but compensating or overlooked evidence may change the conclusion. INTELLIAUDIT adapts this idea to audit evidence by using a Defender agent to challenge adverse findings and a Judge agent to adjudicate disagreements. The benchmark also requires reasoning over enterprise documents and visual artifacts, connecting to work on layout-aware and multi-

modal document understanding such as DocLLM (Wang et al. 2024).

Conceptual Auditing Model

We propose a conceptual model for audit assistance that captures three elements required for evidence-based control assessment: dependencies among audit requirements, mappings from requirements to admissible evidence, and the explainable recommendation task performed for auditors. The model is intentionally domain-agnostic. It can be instantiated for security, privacy, financial, or regulatory audits by specializing the requirement set and artifact taxonomy.

Within this model, INTELLIAUDIT is an interactive audit assistant that works alongside a human auditor. It first helps identify the relevant controls and supporting policy documents, then asks follow-up questions to clarify the system under assessment. It subsequently requests supporting evidence, evaluates whether that evidence is sufficient for each control, asks for additional samples when necessary, and produces an evidence-grounded recommendation package for auditor review. The formal model below defines the objects that this workflow operates over; Section then describes how INTELLIAUDIT operationalizes them through retrieval, adversarial review, adjudication, and human feedback.

Audit Requirement Graph

Let $R = \{r_1, r_2, \dots, r_n\}$ denote the set of audit requirements defined by a given standard or regulatory framework. We model prerequisite relationships among requirements as a directed graph $G = (R, \mathcal{P})$, where an edge $(r_i, r_j) \in \mathcal{P}$ indicates that requirement r_i must be satisfied before requirement r_j can be meaningfully evaluated.

The graph G induces a partial order over R and is assumed to be acyclic, reflecting the logical constraint that an audit requirement cannot depend on its own satisfaction. A *critical path* is defined as any maximal directed path

$$r_{i_1} \rightarrow r_{i_2} \rightarrow \dots \rightarrow r_{i_k},$$

where the satisfaction of each requirement is a prerequisite for the next. Requirements appearing earlier along a critical path represent foundational conditions whose absence invalidates downstream audit claims.

For computational purposes, G can be encoded as a dependency matrix $D \in \{0, 1\}^{n \times n}$, where $D_{ij} = 1$ if and only if $(r_i, r_j) \in \mathcal{P}$. This representation enables automated traversal and identification of blocking requirements.

Artifact–Requirement Mapping

Each audit requirement $r_i \in R$ must be supported by one or more evidentiary artifacts. Let $\mathcal{A}$ denote the universe of acceptable artifacts. We define a mapping

$$\alpha : R \rightarrow 2^{\mathcal{A}},$$

where $\alpha(r_i)$ specifies the set of artifact types acceptable as evidence for satisfying r_i . For a target requirement r_i , the mapping $\alpha(r_i)$ defines the admissible evidence types that an audit assistant should seek and cite.

Artifacts are classified into a finite taxonomy that may include policy and procedure documents, records and logs, configuration snapshots, architectural diagrams, images, and recorded video evidence. Certain artifact types may serve as substitutes for others depending on audit constraints, such as remote audits replacing physical inspections with video evidence.

Audit State and Evaluation

Let $S \subseteq R$ denote the set of requirements currently satisfied by an organization. A requirement r_j is *evaluable* at audit time if and only if all of its prerequisites have been satisfied, i.e.,

$$\forall r_i \in R : (r_i, r_j) \in \mathcal{P} \Rightarrow r_i \in S.$$

This condition formalizes the notion of audit readiness and prevents premature evaluation of dependent requirements. In operational terms, requirements that are not yet evaluable should be surfaced as prerequisite gaps rather than assigned a substantive compliance finding.

Explainable Audit Recommendation Task

Given an evaluable requirement $r_j \in R$ and an engagement-specific evidence corpus $\mathcal{E} \subseteq \mathcal{A}$, INTELLIAUDIT computes

$$F(r_j, \mathcal{E}, S) \rightarrow (\hat{y}_j, \mathcal{B}_j, \Xi_j),$$

where

$$\hat{y}_j \in \{\text{COMPLIANT}, \text{PARTIAL}, \text{NON_COMPLIANT}, \text{INSUFFICIENT_EVIDENCE}\}$$

is an auditor-facing recommendation, $\mathcal{B}_j$ is the supporting evidence for requirement r_j , and Ξ_j is a structured explanation that maps evidence to criteria, highlights gaps or uncertainties, and suggests follow-up or remediation actions.

The goal is not autonomous certification. Rather, the system produces an inspectable recommendation package that a human auditor can review, challenge, and incorporate into the broader audit workflow. This formulation makes explainability first-class: a status recommendation is meaningful only when paired with supporting evidence and a usable rationale. The conceptual model therefore supplies the formal objects used in the methodology: requirements r_j , prerequisite state S , admissible evidence profiles $\alpha(r_j)$, engagement evidence $\mathcal{E}$, evidence bundles $\mathcal{B}_j$, status recommendations $\hat{y}_j$, and explanations Ξ_j .

Methodology

This section operationalizes the conceptual audit model for ISO/IEC 27001:2022 control assessment. Given a target requirement r_j and an engagement corpus $\mathcal{E}$, INTELLIAUDIT approximates the audit function

$$F(r_j, \mathcal{E}, S) \rightarrow (\hat{y}_j, \mathcal{B}_j, \Xi_j),$$

where $\hat{y}_j$ is the recommended compliance status, $\mathcal{B}_j$ is the cited evidence bundle, and Ξ_j is the explanation that links evidence to the requirement. The method is designed for audit assistance rather than autonomous certification: the output is an inspectable recommendation package for a human auditor.

Algorithm 1 IntelliAudit Control Assessment

Require: Requirement r_j ; evidence corpus $\mathcal{E}$
Ensure: Recommendation $\hat{y}_j$, evidence $\mathcal{B}_j$, explanation Ξ_j

```

1:  $A \leftarrow \text{AUDITOR}(r_j, \mathcal{E})$ 
2:  $(\mathcal{B}_A, \Xi_A, \hat{y}_A) \leftarrow A$ 
3: if  $\hat{y}_A \notin \mathcal{V}^-$  then
4:    $(\hat{y}^{(0)}, \mathcal{B}^{(0)}, \Xi^{(0)}) \leftarrow (\hat{y}_A, \mathcal{B}_A, \Xi_A)$ 
5: else
6:    $D \leftarrow \text{DEFENDER}(r_j, \mathcal{E}, A)$ 
7:    $(\mathcal{B}_D, \Xi_D, \hat{y}_D) \leftarrow D$ 
8:    $\mathcal{B}_{AD} \leftarrow \text{DEDUP}(\mathcal{B}_A \cup \mathcal{B}_D)$ 
9:   if  $\hat{y}_D = \hat{y}_A$  then
10:     $\Xi^{(0)} \leftarrow \text{COMBINE}(\Xi_A, \Xi_D)$ 
11:     $(\hat{y}^{(0)}, \mathcal{B}^{(0)}) \leftarrow (\hat{y}_A, \mathcal{B}_{AD})$ 
12:   else
13:     $J \leftarrow \text{JUDGE}(r_j, \mathcal{E}, \mathcal{B}_{AD}, A, D)$ 
14:     $(\mathcal{B}_J, \Xi_J, \hat{y}_J) \leftarrow J$ 
15:     $\mathcal{B}^{(0)} \leftarrow \text{DEDUP}(\mathcal{B}_{AD} \cup \mathcal{B}_J)$ 
16:     $(\hat{y}^{(0)}, \Xi^{(0)}) \leftarrow (\hat{y}_J, \Xi_J)$ 
17:   end if
18: end if
19: if feedback  $h_j$  is supplied then
20:    $H \leftarrow \text{JUDGE}(r_j, \mathcal{E}, \mathcal{B}^{(0)}, \Xi^{(0)}, h_j)$ 
21:    $(\mathcal{B}_H, \Xi_H, \hat{y}_H) \leftarrow H$ 
22:    $\mathcal{B}^+ \leftarrow \text{DEDUP}(\mathcal{B}^{(0)} \cup \mathcal{B}_H)$ 
23:   return  $(\hat{y}_H, \mathcal{B}^+, \Xi_H)$ 
24: end if
25: return  $(\hat{y}^{(0)}, \mathcal{B}^{(0)}, \Xi^{(0)})$ 

```

For each requirement, INTELLIAUDIT derives an evidence profile $\alpha(r_j)$ that describes what kinds of facts would substantiate the control. This profile defines the requirement-specific search space

$$\mathcal{E}_j = \{e \in \mathcal{E} : e \text{ may substantiate some criterion in } \alpha(r_j)\}.$$

The method then decomposes F into three roles. The Auditor performs the primary assessment and proposes $(\hat{y}_A, \mathcal{B}_A, \Xi_A)$. If that assessment is adverse, the Defender searches for overlooked mitigating evidence and proposes $(\hat{y}_D, \mathcal{B}_D, \Xi_D)$. If the Auditor and Defender disagree, the Judge resolves the conflict over the combined evidence bundle $\mathcal{B}_{AD} = \mathcal{B}_A \cup \mathcal{B}_D$ and produces the final recommendation.

This decomposition turns control assessment into a sequence of audit operations: translate the control into evidence needs, retrieve a bounded evidence bundle, evaluate sufficiency, challenge adverse findings, and synthesize a recommendation that remains traceable to cited evidence. Figure 1 presents the staged workflow.

Control Assessment Procedure

Algorithm 1 summarizes the control-level procedure. Let $\mathcal{V}^-$ denote the adverse-status set containing `PARTIAL` and `NON_COMPLIANT`. The Auditor is always invoked. The Defender is invoked only when $\hat{y}_A \in \mathcal{V}^-$, because these are the cases where missed mitigating evidence would materially affect the result. The Judge is invoked only if $\hat{y}_D \neq \hat{y}_A$, so adjudication is reserved for substantive disagreement.

IntelliAudit Methodology: Stages Multi-Agent Retrieval-Grounded Work

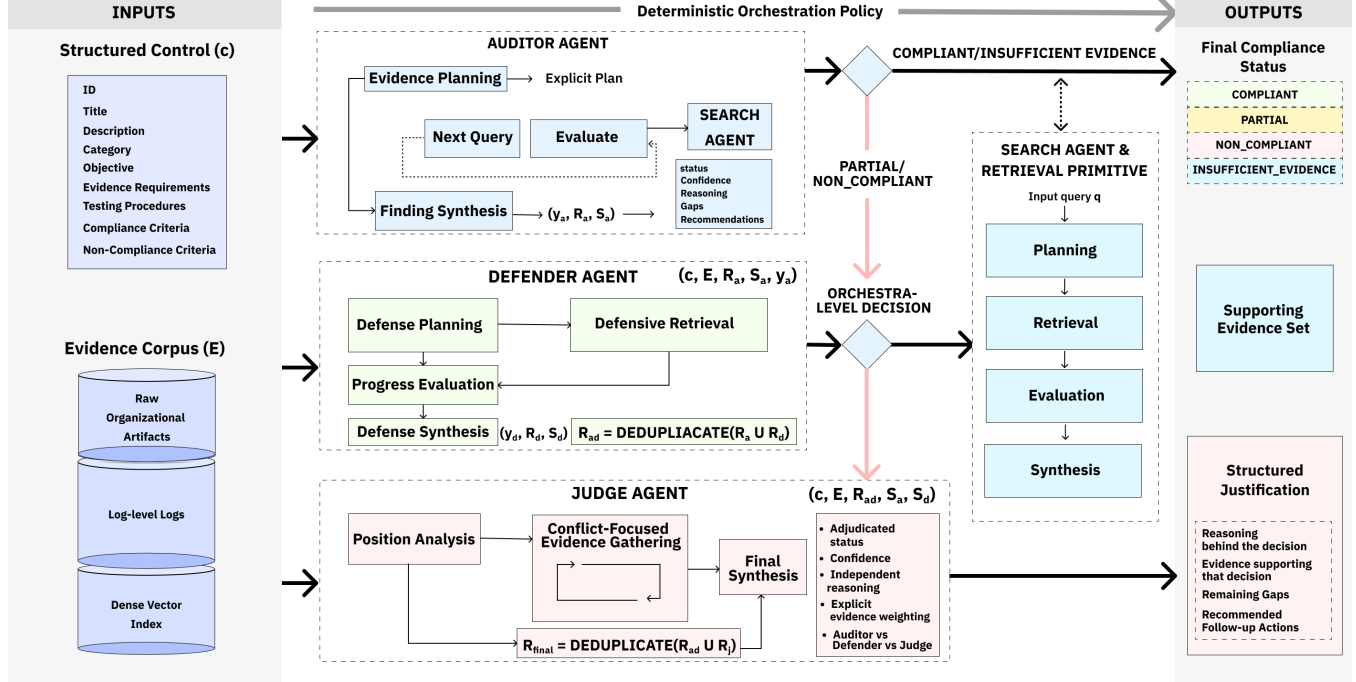


Figure 1: IntelliAudit Methodology: Staged Multi-Agent Retrieval-Grounded Workflow.

Retrieval-Grounded Reasoning

All three decision agents use the same retrieval-grounded reasoning pattern in Algorithm 2. The input x changes by role: for the Auditor, x is the requirement r_j and evidence profile $\alpha(r_j)$; for the Defender, x includes the Auditor's adverse finding; and for the Judge, x includes the conflicting Auditor and Defender positions.

Retrieval is treated as a methodological constraint on reasoning. Each agent first plans what evidence it needs, retrieves candidate evidence from $\mathcal{E}_j$, evaluates whether the bundle is sufficient, and only then synthesizes a status and explanation. The process may expand or pivot the search plan when the current bundle is incomplete, but synthesis is always grounded in the final bundle $\mathcal{B}$. Thus the status decision is not produced from the control text alone; it is produced from an explicit evidence-gathering trace.

Auditor Agent

The Auditor performs the primary approximation of $F(r_j, \mathcal{E}, S)$. It translates r_j and $\alpha(r_j)$ into an evidence plan, retrieves a bounded bundle $\mathcal{B}_A$, and synthesizes $(\hat{y}_A, \Xi_A)$ from that bundle. If the evidence is relevant but incomplete, the Auditor may add targeted queries. If evidence remains insufficient, it reports the gap explicitly rather than inferring unsupported compliance.

Defender Agent

The Defender is a structured challenge mechanism for adverse findings. It is invoked when $\hat{y}_A$ is **PARTIAL** or **NON_COMPLIANT** and attempts to determine whether $\mathcal{B}_A$

Algorithm 2 Generic Retrieval-Grounded Agent Pattern

Require: Agent input x ; evidence corpus $\mathcal{E}$
Ensure: Evidence $\mathcal{B}$; output Ξ ; optional status $\hat{y}$

```

1:  $P \leftarrow \text{PLAN}(x)$ 
2:  $\mathcal{B} \leftarrow \emptyset$ 
3: repeat
4:    $q \leftarrow \text{NEXT\_QUERY}(P)$ 
5:    $\mathcal{B} \leftarrow \mathcal{B} \cup \text{SEARCH}(q, \mathcal{E})$ 
6:    $\mathcal{B} \leftarrow \text{DEDUP}(\mathcal{B})$ 
7:    $d \leftarrow \text{EVALUATE}(x, P, \mathcal{B})$ 
8:   if  $d = \text{STOP}$  then
9:     break
10:  else if  $d$  adds new queries then
11:     $P \leftarrow \text{UPDATE\_PLAN}(P, d)$ 
12:  end if
13: until SAFETY\_LIMIT\_REACHED
14:  $(\Xi, \hat{y}) \leftarrow \text{SYNTHESIZE}(x, P, \mathcal{B})$ 
15: return  $(\mathcal{B}, \Xi, \hat{y})$ 

```

omitted plausible mitigating evidence. Given $\mathcal{B}_A$, $\hat{y}_A$, and Ξ_A , it identifies parts of $\alpha(r_j)$ that may have been underexplored and conducts a focused search for counterevidence. The Defender then synthesizes $\mathcal{B}_A \cup \mathcal{B}_D$ into a suggested revised status $\hat{y}_D$ and explanation Ξ_D . Methodologically, this stage is a lightweight adversarial review before an adverse recommendation is finalized.

Judge Agent

The Judge performs independent adjudication when $\hat{y}_D \neq \hat{y}_A$. Its input is not the full corpus but the conflict state

$(r_j, \mathcal{B}_{AD}, \Xi_A, \Xi_D, \hat{y}_A, \hat{y}_D)$, which focuses judgment on the evidence and reasoning that produced disagreement. The Judge compares the two positions, determines whether the combined evidence is sufficient, and retrieves only conflict-focused evidence when needed. It then synthesizes the final recommendation $(\hat{y}_J, \mathcal{B}^*, \Xi_J)$. The Judge therefore does not merely select between two labels; it reasons over a unified evidence pool and records why one interpretation is better supported.

Interactive Human Feedback

After the system produces an initial recommendation package $(\hat{y}^{(0)}, \mathcal{B}^{(0)}, \Xi^{(0)})$, a human reviewer may provide feedback h_j on the control-level assessment. This feedback can include agreement or disagreement with the recommendation, comments on the reasoning, missing evidence, misunderstood artifacts, or auditor-specific context that was not captured by the retrieved bundle. INTELLIAUDIT treats h_j as an adjudication signal rather than a manual overwrite of the model output.

When feedback is supplied, it is routed to the Judge together with the prior recommendation, explanation, and evidence bundle. The Judge then evaluates whether the feedback identifies a real evidentiary gap, a misinterpretation of existing evidence, or a scope issue requiring additional conflict-focused retrieval. The revised output $(\hat{y}_H, \mathcal{B}^+, \Xi_H)$ preserves the original evidence trace while documenting how human feedback affected the final adjudication. This creates an interactive human-in-the-loop workflow in which auditors can challenge, correct, or supplement the system’s reasoning without breaking the evidence-grounded structure of the method.

Methodological Rationale

INTELLIAUDIT is designed as an audit-assistance workflow rather than an autonomous certification system. This distinction follows from the state variable S : whether a requirement is satisfied depends not only on text similarity, but also on organizational context, scope, compensating controls, and auditor judgment. ISO 27001 permits multiple valid implementations of the same control, so the method emphasizes evidence grounding, adversarial review, interactive human feedback, and inspectable explanations instead of direct automated pass/fail labeling.

System Implementation

The prototype instantiates each control as a structured record containing its identifier, objective, evidence requirements, testing procedures, and compliance criteria. Organizational artifacts are normalized into source-traceable chunks and indexed in a persistent ChromaDB vector store using OpenAI `text-embedding-3-small` embeddings with cosine similarity. Audit retrieval uses the shared SearchAgent configuration with $\text{top-}k = 15$ and a configurable similarity threshold of approximately 0.3–0.35. Retrieved chunks retain source paths, chunk identifiers, scores, and query provenance so that generated findings can be traced back to inspectable artifacts.

The Auditor, Defender, and Judge are implemented as explicit state-machine workflows that track query plans, retrieved evidence, reasoning traces, continuation flags, and termination rationales. Planner and synthesis calls return structured fields and enumerated status values rather than unconstrained free text, providing stable interfaces between retrieval and reasoning. Human feedback from the survey interface is stored separately from generated recommendations and, when available, attached to the relevant control assessment before being passed back to the Judge for re-adjudication.

Benchmark and Evaluation

We evaluate INTELLIAUDIT on the evidence-evaluation stage of an ISO 27001 audit. The goal is not to certify an organization automatically, but to test whether a retrieval-grounded multi-agent system can produce auditor-facing recommendations that are evidence-supported, useful, and robust across heterogeneous audit artifacts.

Benchmark Construction

The benchmark is built around a simulated organization and a curated set of ISO 27001 controls. We select controls that require different forms of audit reasoning: policy interpretation, role-to-responsibility mapping, evidence sufficiency checks, incident-management traceability, asset lifecycle verification, disciplinary enforcement, physical-security observation, and technical access-control review. This design stresses both semantic control understanding and artifact-grounded reasoning. The current benchmark contains 14 planned controls. Table 1 summarizes the control set and primary evidence modalities.

Evidence corpus. Because real audit evidence is sensitive and rarely public, we construct a three-tier corpus. *Real-world artifacts* provide authoritative seed material, including public standards and guidance documents. *Expert-crafted artifacts* simulate operational evidence that organizations commonly produce but rarely disclose, such as organizational charts, asset inventories, screenshots, and multimedia records. *Synthetic artifacts* provide policy and procedural documents generated from the real-world and expert-crafted seeds. The full artifact inventory, generation prompts, and seed dependencies are reported in Appendix .

Evaluation Questions. The evaluation is organized around the four research questions introduced in Section . Table 2 maps each question to the corresponding evaluation signal.

Experimental Setup

For each control, the system retrieves evidence from the artifact corpus and generates a structured recommendation package containing a status label, cited evidence, rationale, missing-evidence analysis, and recommended follow-up actions.

Baselines and ablations. We compare the full multi-agent workflow against a single-agent ablation. The ablation uses the same evidence corpus, retrieval configuration, and model backbone, but removes the Defender and Judge stages. This

Control	Control objective	Primary artifacts	Condition	Reasoning	Evidence use	Usefulness
5.1	Policies for information security	DOC	Single-agent	–	–	–
5.2	Security roles and responsibilities	PDF	Full INTELLIAUDIT	–	–	–
5.9	Inventory of information and associated assets	XLS/XLSX				
5.11	Return of assets	XLS/XLSX				
5.24	Security incident management planning and preparation	DOC				
5.25	Assessment and decision on security events	DOC				
5.26	Response to security incidents	DOC				
5.27	Learning from security incidents	DOC				
5.29	Security during disruption	DOC				
5.30	ICT readiness for business continuity	DOC				
6.4	Disciplinary process	TXT, PNG				
7.7	Clear desk and clear screen	DOC, MP4				
7.14	Secure disposal or reuse of equipment	PDF				
8.1	User endpoint devices	PNG				
8.4	Access to source code	PNG				

Table 1: ISO 27001 controls used in the INTELLIAUDIT benchmark. The benchmark covers textual, tabular, and image-based evidence.

RQ	Source	Evaluation signal
RQ1	Audit experts	Whether the explanation demonstrates control understanding beyond surface keyword matching.
RQ2	Audit experts	Whether cited evidence is factually relevant and sufficient for the assigned status.
RQ3	System logs and expert review	Whether the system processes each artifact modality and preserves source-grounded reasoning.
RQ4	Compliance users	Whether the output helps non-auditors identify and remediate audit-readiness gaps.

Table 2: Mapping from research questions to evaluation evidence.

isolates the effect of adversarial review and adjudication from the effect of retrieval alone.

Human Study Protocol

Because there is no public ground-truth dataset for ISO 27001 evidence sufficiency, we use human evaluation as the primary reference. Participants are divided into two groups. *Group A* consists of practicing auditors who evaluate whether the model’s reasoning and evidence use are professionally acceptable. *Group B* consists of cybersecurity master’s students and compliance professionals who simulate organizational users preparing for an audit and evaluate whether INTELLIAUDIT helps them identify and remedy deficiencies.

Each participant is assigned one of four simulated organizational profiles and reviews controls sequentially, beginning with Control 5.1. The survey uses 5-point Likert-scale questions with free-text justification fields for neutral or negative responses. Group A compares full multi-agent outputs

Table 3: Main human-evaluation results. Values should report mean Likert scores or percentage of outputs rated $\geq 4/5$.

against single-agent ablation outputs. Group B evaluates usefulness, actionability, and clarity of remediation guidance. The expected completion time is approximately 90 minutes for Group A and 450 minutes for Group B.

Insert number of Group A participants, number of Group B participants, recruitment criteria, ethics statement if applicable, and anonymized survey URL or appendix reference.

Metrics

We report four classes of metrics.

Expert-rated reasoning quality. For RQ1 and RQ2, auditors rate control understanding, factuality of evidence use, sufficiency of the conclusion, and clarity of the explanation. We report mean Likert scores, standard deviations, and the percentage of outputs rated at least 4 out of 5.

Ablation preference. For the multi-agent comparison, we report the fraction of controls for which auditors prefer the full INTELLIAUDIT output over the single-agent output. We also report ties and cases where the ablation is preferred.

Artifact coverage. For RQ3, we report whether each artifact modality can be processed end-to-end and whether the final recommendation cites modality-specific evidence. Modalities include DOC/DOCX, PDF, TXT, XLS/XLSX, and PNG.

Practical usefulness. For RQ4, Group B rates whether the output identifies concrete gaps, explains what evidence is missing, and provides actionable remediation guidance. We summarize Likert scores and representative qualitative comments.

Survey Results

The questionnaire and the auditor’s reasoning can be found in Appendix B <Update Appendix Letter>.

<placeholder: INSERT CHART HERE>

Results

Overall performance. Table 3 provides the planned reporting format for the main human-evaluation results. Replace with final survey statistics.

Effect of multi-agent adjudication. The ablation study evaluates whether the Defender and Judge improve the final recommendation. We expect improvements primarily in adverse or ambiguous cases, where the Auditor may miss compensating evidence or overstate a deficiency. Insert the final preference rate: auditors preferred full INTELLIAUDIT in X/Y controls, preferred the ablation in X/Y controls, and marked X/Y ties.

Evidence-modality analysis. The system successfully processed textual documents, PDFs, spreadsheets, text records, and PNG screenshots in the completed evaluation. Video evidence remains a limitation in the current prototype because the MP4 artifact could not be evaluated within the tested context-window constraints. Insert per-modality success rates and representative failure cases.

Qualitative failure modes. We track four recurring failure modes: unsupported compliance claims, insufficiently specific evidence citations, missed compensating controls, and weak remediation guidance. Insert counts and examples from auditor comments.

Dataset Construction Details

Because IT audit evidence is inherently sensitive and rarely made publicly available by organizations, we constructed a simulated organization to serve as the subject of the audit. This organization was given a realistic executive structure, including a Chief Executive Officer (James Byrne), Chief Information Security Officer (Sarah Johnson), Chief Technology Officer (David Thompson), Chief Operations Officer (Robert Chen), Chief Financial Officer (Lisa Martinez), and Chief Human Resources Officer (Amanda Taylor). These roles and their associated responsibilities were defined in accordance with governance guidance from NIST SP 800-100 and the role definitions embedded in the organization’s own information security policy, which was itself generated as part of the artifact corpus. Establishing a consistent and credible organizational identity before generating any evidence artifacts was essential, as all subsequent synthetic documents, disciplinary records, and procedural evidence were grounded in this shared organizational context, giving them internal coherence and audit credibility.

The dataset assembled for this study was organized into three tiers: Real World Data, Expert Crafted Data, and Synthetic Data. This taxonomy reflects the practical reality that building a comprehensive ISO27001 audit dataset from purely organic sources is not feasible, given the sensitive nature of the material involved. Real World Data consists of publicly available authoritative documents that provide the normative and procedural foundation for the entire dataset. These include the ISO/IEC 27001:2022 standard itself, the Province of British Columbia’s Information Security Policy (version 5.0, August 2025), NIST SP 800-61 Revision 3 (Computer Security Incident Handling), NIST SP 800-34 Revision 1 (Contingency Planning), and NIST SP 800-100 (Information Security Handbook for Managers). These documents were used both as direct evidence where appropriate and as seed material for synthetic generation, ensuring that all generated artifacts were grounded in real-world regulatory and procedural language rather than produced from the model’s priors alone.

Expert Crafted Data consists of artifacts created by the research team to simulate the kinds of evidence that organizations produce operationally but rarely disclose publicly. This tier includes the organizational chart for the simulated company, asset inventory spreadsheets covering multiple simulated organizational profiles at varying levels of compliance maturity (from compliant to non-compliant), a video artifact for clear desk and clear screen policy testing, and screenshots representing user access provisioning and source code repository permissions. These artifacts were created to reflect realistic enterprise patterns; for example, asset inventories were constructed to reflect consistent vendor procurement relationships, realistic geographic distribution across Canadian cities, and appropriate data center configurations, rather than random data that would fail to reflect how real organizations actually operate.

Synthetic Data consists of policy and procedural documents generated by an LLM using the Real World and Expert Crafted artifacts as seed inputs. For each synthetically generated artifact, a consistent baseline prompt was used: "You are

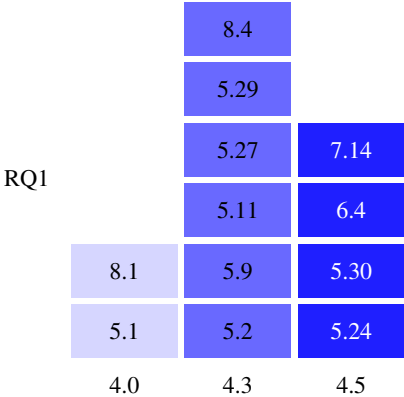


Figure 2: RQ1 — “The recommendation shows the AI understands the control language beyond a layman’s understanding.” ISO 27001:2022 controls grouped by mean auditor agreement (5-point Likert; overall mean 4.32, 86%).

generating data samples for use in an ISO27001 audit. Use the files uploaded in the project as context for the generated data samples." This was then supplemented by a control-specific prompt that directed the model toward the appropriate document type, organizational voice, and compliance objective. All synthetic generation was performed using Claude Sonnet 4.5 with the organizational chart and the relevant ISO controls provided as mandatory seed context in every generation call. The synthetic artifacts produced through this process include the organization’s Information Security Policy (Control 5.1), Business Continuity Plan (5.29), ICT Readiness Plan (5.30), Incident Management Policy (5.24), Incident Response Report (5.27), and a three-document disciplinary evidence chain for Control 6.4 consisting of a verbal warning, a written warning, and a termination letter, all involving a consistent fictitious employee and following a progressive enforcement narrative across the three documents. The complete artifact inventory is detailed in Tables 4 and 5, with each artifact’s data tier, seed inputs, and generation prompt documented for reproducibility.

Tables

Survey Responses <Update Info>

Our survey was completed by 5 auditors and 21 students. Overall we had fairly positive results. Our question if the LLM understands the control language beyond a surface level scored an average of 4.316 or 86% (Figure 2) showing that Sonnet-4.5 understands the underlying body of knowledge necessary to properly understand and evaluate these controls.

#	Artifact	Control #	Data Type
R1	ISO_IEC_27001_2022en.pdf	N/A	Real World
R2	BC_isp_v50_aug2025.pdf	N/A	Real World
R3	NIST SP 800-61 Rev 3.pdf	N/A	Real World
R4	NIST SP 800-34r1.pdf	N/A	Real World
R5	NIST SP 800-100.pdf	N/A	Real World
E1	5-2_Org_Chart.pdf	5.2	Expert Crafted
E2	C_Global_Enterprises_Inc_Asset_Inventor	5.9, 5.11	Expert Crafted
E3	SC_GlobalFinance_Partners_Asset_Data.xls	5.9, 5.11	Expert Crafted
E4	SC_QuickServe_Restaurants_LLC_Asset_Data.xls	5.9, 5.11	Expert Crafted
E5	SC_TechInnovate_Inc_Asset_Data.xlsx	5.9, 5.11	Expert Crafted
E6	SC_WestRange_Logistics_Inc_Asset_Data.xls	5.9, 5.11	Expert Crafted
E7	NC_BuildRight_Construction_Asset_Data.xls	5.9, 5.11	Expert Crafted
E8	NC_MetroRetail_Group_Asset_Data.xlsx	5.9, 5.11	Expert Crafted
E9	7-7_cover-a-guy-working-on-a-pc-18-1080p.mp	7.7	Expert Crafted
E10	8-1_Okta_User_List.png	8.1	Expert Crafted
E11	8-4_Code_Repo_Access_List.png	8.4	Expert Crafted

Table 4: Non-Synthetic Data: Real World and Expert Crafted Artifacts

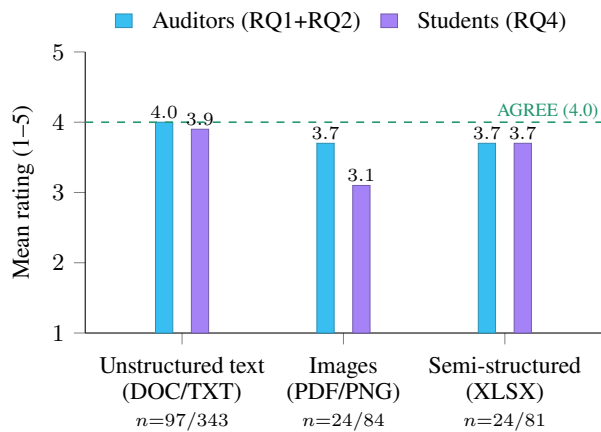


Figure 3: RQ3: reasoning across multi-modal artifacts. Rated responses averaged by primary artifact type of the evidence. Ratings are on a 1–5 agreement scale; n gives auditor/student rating counts.

#	Artifact	Control #	Data Type	Seed	Model	Additional Prompt
S1	5-1_information_security_policy.docx	5.1	Synthetic	E1, R1, R4	Sonnet_4.5	This is the Information Security policy for the Provençal Government of British Columbia. Please adapt the Information Security policy to fit my organization and ensure it is compliant with NIST SP 800-100.
S2	5-29_BCP	5.29	Synthetic	E1, S1, R1, R4	Sonnet_4.5	Based on the attached artifacts, please create a Business Continuity Plan for my organization.
S3	5-24_Incident_Management_Policy.docx	5.24	Synthetic	E1, S1, R1, R3	Sonnet_4.5	Attached is the NIST Standard for incident response. Please create for my org an Incident Management Policy in accordance with ISO27001 control 5-24.
S4	5-27_incident_response_report.docx	5.27	Synthetic	E1, S1, S3, R1, R3, R	Sonnet_4.5	Attached is my Incident Management Policy and the NIST standard for incident response. Please create for me an incident response report.
S5	6-4_Verbal_Warning.txt	6.4	Synthetic	E1, S1, R1, R5	Sonnet_4.5	I am trying to create examples of a three strike policy in action. Please create for me an email from Sarah Johnson (CISO) to Amanda Taylor (CHRO) documenting the fact that Sarah reprimanded Joseph Thomas (on the IT Operations team) for an Information Security policy violation.
S6	6-4_Written_Warning.txt	6.4	Synthetic	E1, S1, S5, R1, R5	Sonnet_4.5	It seems that Joseph Thomas has once again violated policy. Please create a written warning for similar but difference violations of the Information Security Policy.
S7	6-4_Termination_Letter.txt	6.4	Synthetic	E1, S1, S5, S6, R1, R5	Sonnet_4.5	It seems Joseph Thomas is a problem employee and has for a third and final time violated the Information Security policy. Please generate a formal termination letter written from Amanda Taylor to Joseph Thomas.

Table 5: Synthetic Data: AI-Generated Audit Artifacts

References

- Agarwal, B.; Jomraj, H. S.; Kaplunov, S.; Krolick, J.; and Rojkova, V. 2025. RAGulating Compliance: A Multi-Agent Knowledge Graph for Regulatory QA. arXiv:2508.09893.
- Brachten, C. E. W.; and Riasat, S. I. 2024. Automating ISO 27001 Consultancy and Auditing using AI: A Feasibility Study Based on Expert Interviews. Preprint, Utrecht University, supervised by R. L. Jansen.
- Du, Y.; Li, S.; Torralba, A.; Tenenbaum, J. B.; and Mordatch, I. 2023. Improving Factuality and Reasoning in Language Models through Multiagent Debate. arXiv:2305.14325.
- McIntosh, T. R.; Susnjak, T.; Liu, T.; Watters, P.; Nowrozy, R.; and Halgamuge, M. N. 2024. From COBIT to ISO 42001: Evaluating Cybersecurity Frameworks for Opportunities, Risks, and Regulatory Compliance in Commercializing Large Language Models. arXiv:2402.15770.
- Rastogi, C.; Ribeiro, M. T.; King, N.; Nori, H.; and Amershi, S. 2023. Supporting Human-AI Collaboration in Auditing LLMs with LLMs. arXiv:2304.09991.
- Wang, D.; Raman, N.; Sibue, M.; Ma, Z.; Babkin, P.; Kaur, S.; Pei, Y.; Nourbakhsh, A.; and Liu, X. 2024. DocLLM: A Layout-Aware Generative Language Model for Multimodal Document Understanding. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, 8529–8548. Bangkok, Thailand: Association for Computational Linguistics.
- Yao, X.; Wu, X.; Li, X.; Xu, H.; Li, C.; Huang, P.; Li, S.; Ma, X.; and Shan, J. 2024. Smart Audit System Empowered by LLM. arXiv:2410.07677.